ARE GROUPS THE SAME AS ROLES?

At first glance, groups and roles may look interchangeable—they both represent collections of users, and both can be used to assign permissions. But while they're closely related, they serve different purposes and come from different parts of the system architecture.

Groups are collections of identifiers that are used to organize identity; for instance, assigning users to various departments or teams in an identity provider such as LDAP or Active Directory.

Roles are designed to express authorization logic: which actions someone can perform and in what context.

In practice, groups and roles often interact. A group like engineering might map directly to a role, such as engineer, or it might be used to dynamically determine role assignment. Some systems even treat groups as roles, blurring the line entirely.

RBAC adds more structure than simple group-based access:

- Roles link to permission sets, while groups usually do not.
- RBAC supports role hierarchies and separation of duty constraints.
- Roles often have governance processes, while groups are more often managed informally.

Bottom line: all roles are groups, but not all groups are roles. Groups might be used to assign roles, but they aren't roles themselves. RBAC builds on the idea of grouping to introduce a more formal, policy-aligned way of managing access.

5.2.2 Mapping RBAC onto the authorization reference architecture

RBAC naturally aligns with the authorization reference architecture introduced in chapter 4. While the core ideas remain the same—evaluate a